

Cyber Tabletop Exercise

Government Procurement Data Leak

Insider Exfiltration via Removable USB Media

Exercise Attribute	Value
Target organization	National Procurement Office
Sector	Government
Primary impacted asset	Internal Procurement File Repository
Threat actor	Malicious Insider
Exercise duration	75-90 minutes
Audience	Executive crisis leadership, legal/HR/comms, SOC/IR, procurement leadership, records/data owners
Source	STIX 2.1 bundle supplied by user; enriched for exercise facilitation

EXERCISE ONLY - FICTIONAL SCENARIO

1. Executive Summary

This tabletop exercise simulates a government procurement data leak caused by a suspected malicious insider who uses privileged access and personal removable media to copy sensitive procurement documents. The scenario begins when journalists contact the National Procurement Office after procurement files appear on a public file-sharing site. Participants must coordinate incident response, evidence preservation, HR/legal actions, executive decision-making, public communications, and regulatory notification while maintaining integrity of procurement operations.

Exercise purpose

- Test the organization’s ability to detect, triage, escalate, and manage a suspected insider data leak.
- Validate coordination between SOC/IR, procurement leadership, legal, HR, communications, records management, privacy/data protection, and executive crisis leadership.
- Exercise decision-making for containment, evidence preservation, employee access suspension, media response, supplier impact assessment, and regulator notification.
- Identify improvements to removable media controls, privileged access monitoring, data loss prevention, logging, and procurement confidentiality controls.

Scenario source elements

STIX Element	Exercise Use
National Procurement Office	Victim organization and exercise audience context
Internal Procurement File Repository	Document repository containing procurement plans, supplier evaluations, and contract negotiation materials.
Malicious Insider	Privileged employee suspected of copying and leaking procurement documents.
Removable USB Storage Device	Personal removable media used to copy sensitive procurement files.
Exfiltration Over Physical Medium (T1052)	Primary ATT&CK technique reflected in the scenario
Government Procurement Data Leak	Sensitive procurement documents are leaked publicly following suspected insider exfiltration.

2. Scope, Participants, and Assumptions

In scope

- Crisis management activation and executive escalation.
- Initial cyber triage, log review, endpoint evidence preservation, and containment.
- Insider-risk handling in partnership with HR and legal.
- Communications to ministers/senior officials, suppliers, impacted internal teams, media, and regulators.
- Procurement integrity, supplier fairness, contract negotiation sensitivity, and operational continuity.
- Lessons learned and corrective action planning.

Out of scope

- Technical malware reverse engineering or hands-on forensic lab work.
- Disciplinary determinations beyond exercise discussion; actual employee actions must follow policy and law.
- Attribution beyond what is presented in injects.
- Real notifications to regulators, suppliers, or media.

Recommended participants

Role / Function	Expected contribution
Executive / Crisis Chair	Set priorities, approve major decisions, ensure cross-functional coordination.
CISO / Security Lead	Own cyber triage, containment, evidence preservation, and technical risk reporting.
SOC / Incident Response	Analyze logs, validate file access and USB events, preserve forensic evidence.
Procurement Leadership	Assess sensitivity of leaked material, supplier impacts, and procurement integrity.
Legal Counsel	Advise on employee action, privilege, notification obligations, litigation risk, and evidence handling.
HR / Employee Relations	Coordinate employee access suspension, interview protocol, and disciplinary process.
Communications / Public Affairs	Prepare holding statements, media lines, internal messaging, and stakeholder Q&A.
Privacy / Data Protection / Records	Determine if personal or protected data is present and notification duties.
Business Continuity / Operations	Maintain procurement processes and identify alternate workflows.

Key assumptions

- The leaked documents include procurement plans, supplier evaluations, and contract negotiation materials; some documents may include personal or commercially sensitive information.
- The suspected insider is a privileged procurement analyst with legitimate access to the repository.
- The exercise organization has an SOC, incident response procedures, HR/legal escalation paths, and a crisis management structure.
- All inject times are exercise time and may be compressed by the facilitator.

3. Objectives and Success Criteria

Objective	Success indicators
O1 - Escalation and governance	Participants identify the correct incident severity, activate appropriate cyber/crisis governance, and clarify decision rights between SOC/IR, crisis leadership, HR, legal, and procurement.
O2 - Containment and evidence preservation	Participants preserve repository, endpoint, USB, identity, and access logs before disabling access or interviewing the suspected employee.
O3 - Insider-risk coordination	Participants coordinate lawful employee access suspension, HR involvement, interview approach, chain of custody, and least-privilege containment.
O4 - Communications and stakeholder management	Participants produce consistent internal, executive, media, supplier, and regulator communication priorities without over-disclosing unverified facts.
O5 - Regulatory and procurement impact management	Participants identify notification triggers, procurement fairness risks, affected tenders/contracts, and corrective actions.
O6 - Control improvement	Participants identify gaps and action owners for removable media controls, DLP, privileged activity monitoring, access reviews, and offboarding/change-of-role processes.

Exercise success looks like

- Clear incident owner and crisis chair are named within the first inject.
- SOC/IR actions are distinguished from executive crisis decisions; technical containment is not delegated to a non-technical crisis cell.
- Legal and HR are engaged before employee confrontation or disciplinary action.
- Evidence preservation occurs before broad remediation.
- Media response is coordinated, factual, and aligned with legal and regulator strategy.
- Lessons learned produce concrete owners, timelines, and measurable control improvements.

4. Rules of Engagement

- This is a no-fault learning exercise; there are no perfect answers.
- Real incidents take priority. Participants may step out if required.
- Participants should respond from their actual roles, authorities, tools, policies, and escalation paths.
- Do not fight the scenario. Treat the injects as true for exercise purposes unless the facilitator says otherwise.
- Avoid naming real employees or suppliers. Use role-based labels in discussion.
- All decisions, assumptions, gaps, and action items should be captured by the scribe.
- Exercise material is confidential and should not be distributed externally.

Facilitator guidance

- Prompt participants to separate facts from assumptions.
- Ask who owns each action and when it should occur.
- Challenge premature public statements and premature employee action before evidence preservation.
- Keep the group focused on decision-making, communications, and coordination rather than forensic minutiae.
- Use time pressure: journalists, senior officials, and suppliers are seeking answers before the investigation is complete.

5. Scenario Narrative

The National Procurement Office maintains an internal procurement file repository containing procurement plans, supplier evaluations, and contract negotiation materials. The repository is accessed by procurement analysts, sourcing leads, legal reviewers, and senior procurement management. Some files are highly sensitive because they could influence supplier behavior, undermine open procurement fairness, expose negotiation positions, or create reputational and legal risk if disclosed.

A privileged procurement analyst is suspected of downloading a large number of sensitive files and copying them to a personal USB storage device. Shortly afterward, selected documents appear on a public file-sharing site. Journalists begin contacting the department for comment. As the situation develops, endpoint logs connect the suspicious activity to a personal removable media device, and media outlets publish details from the documents.

Threat model

Threat element	Description
Actor	Malicious insider with legitimate access to sensitive procurement data.
Access path	Authorized repository access used in an unusual pattern: bulk downloads followed by removable media use.
Exfiltration path	Personal USB storage device connected to an endpoint after bulk access.
Business impact	Loss of procurement confidentiality, supplier trust damage, potential procurement challenge, public confidence erosion, legal/regulatory exposure.
Cyber impact	Sensitive data exposure and insider misuse rather than external malware compromise.
Primary decision tension	Contain the insider and preserve evidence while responding to public disclosure and avoiding premature or defamatory statements.

Pre-exercise artifacts suggested for facilitator

- Repository access log excerpt showing unusual bulk downloads.
- Endpoint USB event log showing device insertion and file copy timestamps.
- Media inquiry email asking for confirmation of leaked documents.
- Draft supplier concern email requesting assurance that tender fairness is preserved.
- Regulator notification decision checklist.
- Employee access suspension and evidence preservation checklist.

6. Timeline and Inject Plan

The exercise is designed for 75-90 minutes. The facilitator may compress or expand discussion time depending on the audience.

Time	Inject	Core development	Recommended discussion time
T+0	Inject 1 - Public Disclosure	Journalists report leaked procurement documents on a public file-sharing site.	10-12 min
T+30 min	Inject 2 - Internal Source Identified	Leaked files match internal repository documents; logs show unusual bulk downloads by a procurement analyst.	15-18 min
T+90 min	Inject 3 - USB Evidence	Endpoint logs show personal USB connected and sensitive files copied.	15-18 min
T+4 hrs	Inject 4 - Media and Legal Escalation	Media publishes details; legal, HR, senior leadership, and regulators must coordinate.	20 min
End	Debrief	Capture decisions, gaps, and improvement actions.	15-20 min

7. Detailed Injects and Facilitation Material

Inject 1 - Public Disclosure

Exercise time	Inject message
09:00	Journalists contact the department for comment after sensitive procurement documents appear on a public file-sharing site.

Discussion questions

- What immediate actions should be taken when the organization learns of the public leak?
- Who owns initial triage, and who decides whether to activate crisis management?
- What should be communicated internally before facts are confirmed?
- What is the holding line for journalists?
- How do you preserve public-site evidence without amplifying the leak?

Expected actions / good practices

- Open and classify a security/privacy/procurement incident ticket.
- Activate SOC/IR triage and notify crisis leadership, legal, procurement leadership, communications, privacy, and records owners.
- Preserve screenshots, URLs, file names, timestamps, and copies of public artifacts using approved evidence handling.
- Issue a limited internal need-to-know advisory and instruct teams not to access or redistribute leaked files.
- Prepare a factual media holding statement: aware, assessing, protecting integrity, will provide updates when appropriate.

Facilitator notes

- Look for clarity on incident command and whether cyber, legal, HR, and communications are engaged early.
- Challenge participants who want to deny authenticity before validation.
- Probe whether procurement fairness and supplier confidence are addressed.

Inject 2 - Internal Source Identified

Exercise time	Inject message
10:30	The leaked files match documents stored in the internal procurement repository. Access logs show unusual bulk downloads by a procurement analyst.

Discussion questions

- What evidence must be preserved before disabling accounts or contacting the employee?
- Who is authorized to approve suspension of access and device containment?
- How do HR and legal participate in insider investigation decisions?
- Which suppliers, tenders, or contract negotiations may be affected?
- What additional logs or data sources should be collected?

Expected actions / good practices

- Preserve repository audit logs, identity/access logs, endpoint telemetry, email/chat logs as legally permitted, and SIEM alerts.

- Coordinate with HR/legal before employee contact; avoid tipping off the suspected insider before evidence preservation.
- Restrict or suspend the user's privileged access using an approved emergency access process.
- Map downloaded files to procurement processes, suppliers, tender stages, and sensitivity labels.
- Assess whether personal data, confidential commercial information, or protected government information is present.

Facilitator notes

- Ensure SOC/IR owns technical containment, while the crisis cell owns prioritization, communications, and business decisions.
- Ask how chain of custody is documented.
- Ask whether file repository logging is sufficient to prove exact files accessed.

Inject 3 - USB Evidence

Exercise time	Inject message
12:00	Endpoint logs show a personal USB storage device connected shortly after the bulk downloads. Several sensitive files were copied before the device was removed.

Discussion questions

- What is the containment decision for the endpoint, account, and USB device?
- How do you secure physical evidence if the USB is not in organizational custody?
- What monitoring should be expanded to detect similar behavior by others?
- Do current controls allow personal removable media, and why?
- What are the implications if documents were copied but not all copied files are visible publicly?

Expected actions / good practices

- Isolate and preserve the endpoint; capture forensic image or approved triage package.
- Preserve USB device metadata, serial number, insertion/removal timestamps, file copy artifacts, and EDR/SIEM records.
- Suspend remaining access for the suspected account and rotate credentials/tokens if appropriate.
- Run retrospective searches for removable media events, bulk downloads, archive creation, unusual print/email/upload activity, and privilege misuse.
- Implement temporary compensating controls: block removable media for sensitive repositories, increase alerting, restrict mass downloads, and review privileged users.

Facilitator notes

- Probe whether the organization can enforce USB restrictions immediately.
- Ask whether actions are reversible if the suspicion is incorrect.
- Keep legal/HR considerations central; this is both a cyber and employee-relations matter.

Inject 4 - Media and Legal Escalation

Exercise time	Inject message
15:00	Media outlets publish details from the leaked procurement documents. Legal, HR, and senior leadership must coordinate public response, disciplinary process, and

regulator notification.

Discussion questions

- What public position can be taken now that media has published details?
- Who approves regulator notification, supplier notification, and ministerial/senior government briefing?
- What is the disciplinary process and who may interview the employee?
- How do you protect ongoing procurements and avoid unfair advantage?
- What must be included in the post-incident report?

Expected actions / good practices

- Activate formal crisis communications approval flow involving legal, communications, executive leadership, procurement, privacy, and security.
- Prepare regulator notification decision record with facts, data categories, affected parties, containment status, and open questions.
- Brief senior officials using confirmed facts, impact assessment, decisions needed, and next updates.
- Assess whether affected procurement processes require pause, re-baselining, supplier notification, or independent review.
- Initiate post-incident review with corrective actions for access governance, DLP, removable media, logging, and insider-risk controls.

Facilitator notes

- Challenge over-specific public claims while facts remain incomplete.
- Ask whether supplier notification could prejudice an investigation or procurement fairness.
- Ensure participants identify owners and deadlines for post-mortem deliverables.

8. Decision Points

Decision point	Trigger	Decision owner(s)	Considerations
Incident classification and escalation	Public leak reported and authenticity unknown	CISO/SOC lead with crisis chair	Classify severity, preserve evidence, activate legal/comms/procurement.
Access suspension	Logs identify unusual bulk downloads by named analyst	SOC/IR, HR, Legal, Procurement leadership	Evidence preservation, least privilege, legal basis, business continuity.
Endpoint and USB containment	Endpoint logs show USB copy activity	SOC/IR with Legal/HR support	Forensic imaging, chain of custody, physical custody of device, privacy constraints.
Public/media response	Journalists and media publish details	Communications, Legal, Executive leadership	Do not confirm unverified details; acknowledge assessment; protect investigation.
Regulatory notification	Potential sensitive/government/personal/commercial data exposure	Legal, Privacy, Executive leadership	Notification triggers, timelines, scope, facts, uncertainties, follow-up commitments.
Procurement integrity action	Leaked supplier evaluations/negotiation materials	Procurement leadership, Legal, Executive leadership	Pause or continue tender, supplier fairness, audit trail, independent review.
Control remediation	Incident stabilized	CISO, Procurement, Records, IT	USB restriction, DLP, logging, access review, data classification, privileged access governance.

Escalation logic

The SOC/IR function should own technical validation, preservation, and containment. The crisis leadership function should own business prioritization, stakeholder coordination, communications posture, and decisions with legal, regulatory, or reputational consequences. HR and legal must be engaged before any employee confrontation, interview, or disciplinary action.

9. Technical and Business Impact Analysis

Impact area	Potential impacts	Questions for participants
Confidentiality	Procurement plans, supplier evaluations, negotiation positions, and internal deliberations exposed.	Which documents are confirmed leaked? Which may have been copied but not yet published?
Integrity of procurement process	Supplier fairness may be challenged; ongoing tenders may be compromised.	Should any procurement be paused, re-scoped, re-evaluated, or externally reviewed?
Legal/regulatory	Potential breach of confidentiality, privacy, records retention, labor law, and procurement rules.	Which notification thresholds apply and who approves them?
Operational continuity	Procurement work may slow while access controls and investigations proceed.	What alternate processes keep critical procurements moving safely?
Reputation and trust	Media coverage and supplier concern may damage confidence in procurement integrity.	What consistent message reassures stakeholders without over-disclosing?
Security control posture	Weak removable media control, DLP, bulk download detection, and privileged monitoring may be exposed.	What immediate and long-term controls are needed?

Immediate evidence sources

- Repository access logs, download/export logs, audit trails, file version histories, and permissions.
- Identity provider logs, privileged access management records, VPN/session logs, and MFA events.
- Endpoint detection and response telemetry, USB insertion events, shellbag/recent file artifacts, file copy events, and removable media serial number.
- SIEM alerts, DLP logs, print logs, email/web proxy/cloud upload logs, and collaboration platform activity.
- Public file-sharing page metadata, media inquiries, publication timestamps, and archived evidence copies.

10. Communications Package

Initial internal message

We are aware of reports that documents resembling internal procurement material have appeared on an external file-sharing site. Security, legal, procurement leadership, communications, and privacy teams are assessing the matter. Do not access, download, share, or comment on the files. Route all inquiries to the designated communications and legal contacts.

External holding statement

We are aware of media inquiries concerning documents that may relate to procurement activity. We take the confidentiality and integrity of procurement processes seriously and are assessing the facts. It would be inappropriate to comment on specifics while that assessment is underway. We will take appropriate action based on confirmed information.

Executive briefing template

Field	Content to provide
What happened	Known facts only; distinguish reported, confirmed, and under investigation.
Current impact	Data categories, affected procurement processes, suppliers, and public exposure status.
Actions taken	Evidence preserved, access restricted, incident governance activated, communications controlled.
Decisions needed	Regulator/media/supplier posture, procurement pause/continue decision, resource needs.
Next update	Time, owner, and expected new information.

Regulator notification decision record

- Incident summary and discovery time.
- Confirmed and suspected data categories.
- Affected systems, users, suppliers, and procurements.
- Containment actions and remaining risk.
- Evidence that supports or disputes external disclosure.
- Legal basis for notification or decision not to notify yet.
- Planned follow-up, remediation, and accountable executive.

11. Debrief and Lessons Learned

Hotwash questions

- What did we know, when did we know it, and who needed to know?
- Were escalation paths clear across SOC/IR, crisis leadership, procurement, legal, HR, privacy, and communications?
- Could we preserve the required evidence quickly and defensibly?
- Did we manage the suspected employee in a way that balanced containment, fairness, privacy, and legal defensibility?
- How would we decide whether to pause or continue affected procurements?
- Were media, supplier, regulator, and senior official communications aligned?
- Which controls would have prevented or detected the activity sooner?

Observer confidence ratings

Capability	1 Not confident	2	3	4	5 Fully confident	Notes / evidence
Insider incident escalation						
Evidence preservation and chain of custody						
USB/removable media control						
Privileged access monitoring						
Procurement impact assessment						
Legal/HR coordination						
Media/regulator communications						
Corrective action ownership						

Action tracker

#	Gap / observation	Risk	Owner	Due date	Status
1					
2					
3					
4					
5					

12. Control Improvement Recommendations

Control area	Recommended improvement	Priority
Removable media	Block personal USB storage by default; allow only managed encrypted devices with business justification and logging.	High
Data loss prevention	Deploy or tune DLP for sensitive procurement repositories, including bulk downloads, copy to USB, external upload, and unusual print/email behavior.	High
Repository governance	Apply sensitivity labels, download limits, watermarking where appropriate, and just-in-time access for highly sensitive tender materials.	High
Privileged access	Review privileged procurement users, enforce least privilege, monitor unusual activity, and require periodic access recertification.	High
Insider risk	Create a cross-functional insider-risk playbook covering HR/legal engagement, evidence handling, offboarding, resignation-period controls, and employee privacy.	High
Logging and detection	Correlate repository bulk download events with endpoint USB insertion, file copy, compression, cloud upload, and email attachment activity.	Medium
Procurement resilience	Define playbooks for leaked bid/tender material, including procurement pause criteria, supplier notification, and independent review.	Medium
Training and awareness	Train privileged users on confidentiality obligations and consequences of unauthorized copying or disclosure.	Medium

13. MITRE ATT&CK Mapping

The STIX bundle explicitly identifies Exfiltration Over Physical Medium (T1052). The scenario also reflects related collection, discovery, and defense-evasion/impact considerations that are useful for facilitator discussion. The mapping below distinguishes directly evidenced techniques from inferred supporting behaviors.

Tactic	Technique / Sub-technique	Scenario evidence	Confidence
Exfiltration (TA0010)	T1052 - Exfiltration Over Physical Medium	STIX attack pattern; endpoint logs show personal USB used to copy sensitive procurement files.	Direct
Exfiltration (TA0010)	T1052.001 - Exfiltration over USB	Personal USB storage device connected shortly after bulk downloads and used for file copies.	Direct / enriched sub-technique
Collection (TA0009)	Data from Information Repositories / local file collection (conceptual mapping)	Bulk downloads from internal procurement repository prior to exfiltration. ATT&CK does not have a perfect one-to-one technique for every authorized repository access pattern; use as discussion aid.	Inferred
Collection (TA0009)	T1005 - Data from Local System	Relevant if files were staged locally on the analyst workstation before being copied to USB.	Conditional
Defense Evasion (TA0005)	Valid Accounts / authorized access misuse (conceptual)	The insider used legitimate access rather than malware or credential theft. This is an insider misuse pattern more than a classic external adversary technique.	Contextual
Impact / Business process risk	Procurement confidentiality and process integrity degradation	Leak may affect supplier fairness, negotiations, and public confidence.	Business impact, not an ATT&CK technique

Detection and mitigation links to exercise actions

Exercise action	ATT&CK-aligned detection / mitigation rationale
Correlate USB insertion with unusual file access	Detect removable drive insertion followed by unusual file access, staging, or copying.
Restrict removable media	Reduce opportunity for unauthorized exfiltration over USB.
Monitor and alert on bulk downloads	Identify unusual collection activity before public disclosure.
Apply DLP and sensitivity labels	Detect or block unauthorized transfer of sensitive procurement material.
Enforce least privilege and access recertification	Limit access to sensitive documents to those with current business need.
Preserve endpoint/repository logs	Support defensible investigation and regulator reporting.

References used for ATT&CK mapping

- MITRE ATT&CK: T1052 Exfiltration Over Physical Medium.
- MITRE ATT&CK: T1052.001 Exfiltration over USB.
- MITRE ATT&CK: TA0010 Exfiltration tactic.

- MITRE ATT&CK: DET0123 Detection of Data Exfiltration via Removable Media.
- MITRE ATT&CK: M1057 Data Loss Prevention mitigation.

Appendix A - Facilitator Run Sheet

Segment	Duration	Facilitator action
Welcome, scope, rules	5 min	Set no-fault tone, confirm roles, appoint scribe, remind participants not to fight the scenario.
Objectives and context	5 min	Explain procurement repository sensitivity and insider-risk scenario.
Inject 1	10-12 min	Focus on initial triage, crisis activation, media holding line, evidence preservation.
Inject 2	15-18 min	Focus on internal source, access suspension, HR/legal coordination, logs.
Inject 3	15-18 min	Focus on USB evidence, containment, monitoring expansion, control gaps.
Inject 4	20 min	Focus on media/regulator/supplier strategy, legal process, procurement integrity.
Debrief	15-20 min	Capture decisions, gaps, ratings, and action owners.

Appendix B - Glossary

Term	Definition
ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge framework.
DLP	Data Loss Prevention controls that monitor, detect, or block sensitive data movement.
EDR	Endpoint Detection and Response tooling for workstation/server telemetry and containment.
IR	Incident Response.
SOC	Security Operations Center.
STIX	Structured Threat Information Expression, a standard for representing cyber threat intelligence.
USB evidence	Endpoint and device artifacts showing removable media connection and file copy behavior.
Chain of custody	Documented handling of evidence from collection through analysis and storage.